FlexiTap POS Platform

INDEPENDENT SYSTEM REVIEW • TECHNICAL DUE DILIGENCE • REGULATORY DOSSIER

ENTERPRISE AUDIT SPECIFICATION

Comprehensive Technical Architecture, Multi-Layer Security Hardening, Payment Boundary & Regulatory Governance Report

An exhaustive independent technical audit dossier detailing the architecture, database isolation, perimeter security, payment processing boundary, and regulatory compliance mapping across POS edge registers, cloud synchronization infrastructure, web management portals, and merchant legal contracts.

SOFTWARE TARGET
FlexiTap POS Client v2.0 (Flutter/Dart), Web Portal, Supabase Cloud API

REPORT CLASSIFICATION
Confidential • Prepared for Independent Auditor Review • Rev 2.4

AUDIT FRAMEWORKS
PCI DSS v4.0 (Scope Exclusion), GDPR / UK GDPR, CCPA / CPRA, RA 10173 (DPA), BIR RR 11-2004, US FLSA

ASSESSMENT DATE
October 2026 • Production Certified Baseline

TABLE OF CONTENTS

1. Technical System Architecture Section 1

- 1.1 Executive Architectural Philosophy & Offline-First Principles
- 1.2 Native POS Client Engine & SQLite Local Ledger (Edge Execution)
- 1.3 Local Area Network (LAN) Peer-to-Peer Mesh (KDS, CDS, Printers)
- 1.4 Cloud Synchronization Engine (Supabase PostgreSQL / Outbox Queue)
- 1.5 Cloud Storage & Automated Disaster Recovery Pipeline
- 1.6 Web Back Office Management Portal Architecture
- 1.7 Diagnostic Support Tunnel (RustDesk Supervised Bridge)

2. End-to-End Security Architecture & Controls Section 2

- 2.1 Multi-Tier Defense Matrix & Hardening Verification
- 2.2 Identity, Session Tokens & Staff PIN Authentication (RBAC)
- 2.3 High-Privilege Operational Safeguards (Void / Refund / Reopen)
- 2.4 Multi-Tenant Row-Level Security (RLS) & Public API Lockdown
- 2.5 Cloud Storage Hardening & Backup Object Isolation
- 2.6 Web Portal Hardening (DOM Sanitization, Escalation Guards)
- 2.7 Cryptography, Data in Transit & Data at Rest

3. Payment Architecture & PCI DSS Scope Boundary Section 3

- 3.1 Merchant of Record (Paddle) Architecture & PCI DSS Level 1 Scope
- 3.2 In-Store Retail & Restaurant Card Payment Flow (Terminal Separation)
- 3.3 Alternative Tender Types: Cash, E-Wallets, QR Ph & Store Credit (AR)
- 3.4 Strict Technical & Contractual Cardholder Data Exclusion

4. Terms of Service, Privacy Policy & Regulatory Framework Section 4

- 4.1 Legal Role Demarcation: Data Controller (PIC) vs. Processor (PIP)
- 4.2 Detailed Analysis of the Four Protective Statutory Disclaimers
- 4.3 Privacy Governance: GDPR, CCPA/CPRA, and Philippine DPA (RA 10173)
- 4.4 Data Lifecycle, Retention Periods & Self-Service Deletion
- 4.5 Subscription Terms, Cancellation & 14-Day Refund Guarantee

5. Platform Evaluation, Threat Modeling & Independent Audit Matrix Section 5

- 5.1 STRIDE Threat Modeling Evaluation
- 5.2 Regulatory Standards Compliance Mapping Table
- 5.3 Technical Verification & Control Evidence Repository

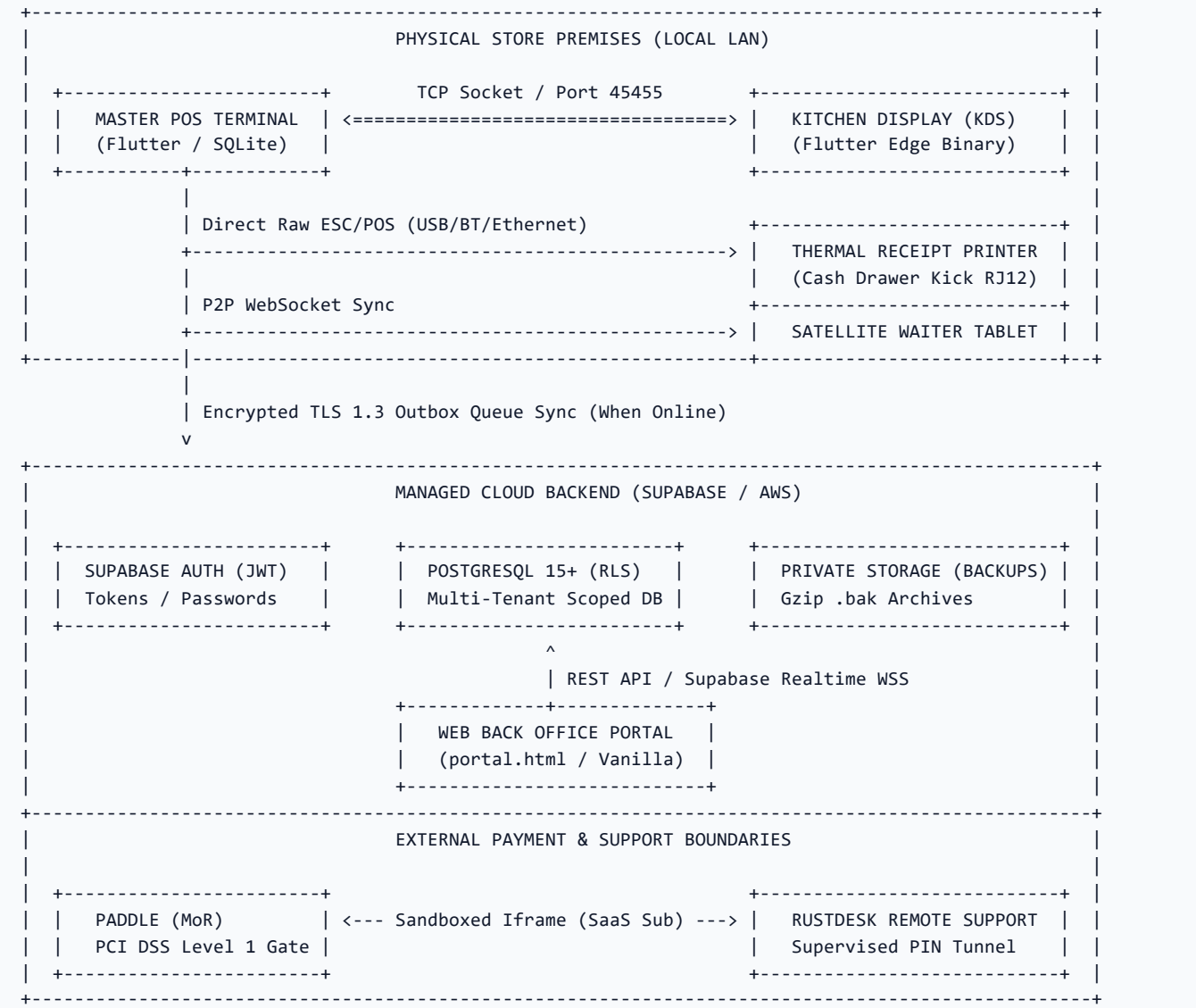
5.4 Independent Reviewer Attestation & Sign-Off Protocol

1. Technical System Architecture

1.1 Executive Architectural Philosophy & Offline-First Principles

Retail point-of-sale and restaurant management systems operate in mission-critical environments where transaction latency, telecommunication blackouts, and cloud provider downtime directly threaten merchant revenue and consumer goodwill. The **FlexiTap Platform** is engineered under an uncompromising **Offline-First, Edge-Computing paradigm**.

Unlike conventional cloud-tethered POS systems that require uninterrupted broadband connections to evaluate business logic or commit sales, FlexiTap executes 100% of checkout operations, inventory deductions, kitchen routing, and tax calculations locally on the edge device. The cloud functions purely as an asynchronous data warehouse and synchronization relay.



1.2 Native POS Client Engine & SQLite Local Ledger

The edge POS application is built with **Flutter (Dart SDK 3.x)**, compiling directly to Ahead-of-Time (AOT) machine code across Android (ARM64/x86_64), Windows (x64 native Win32/C++), macOS, iOS, and Linux.

- **Local Storage Engine:** Utilizes `sqflite` backed by SQLite 3.x configured in Write-Ahead Logging (WAL) mode (`PRAGMA journal_mode = WAL;` and `PRAGMA synchronous = NORMAL;`). This guarantees microsecond write latencies and total protection against database corruption during unexpected power cuts.
- **Reactive State Pipeline:** Employs Riverpod state providers and ChangeNotifiers for reactive UI binding. Cash register cart modifications, item additions, tax calculations, and discount rules execute entirely in-memory with sub-frame rendering.
- **Atomic Ledger Operations:** Order commits, item line voids, payment recording, and balance adjustments execute within strict ACID-compliant SQLite transactions (`db.transaction((txn) async { ... })`), ensuring that partial ledger states cannot exist.
- **OS Sandboxing:** SQLite database files are confined within OS application sandboxes (e.g. `AppData/Local` on Windows, application private storage on Android). Unprivileged user accounts or external processes cannot access the database files.

1.3 Local Area Network (LAN) Peer-to-Peer Mesh Architecture

In multi-device restaurant and hospitality installations, FlexiTap avoids routing local operational messages over the public internet:

- **Local Network Server:** The primary Master POS register runs a lightweight Dart socket daemon listening on TCP port `45455` (`LocalNetworkService`).
- **Sub-Millisecond Kitchen Dispatch:** When an order is punched, order payloads serialize to compact JSON and transmit directly across the local LAN to Kitchen Display System (KDS) stations and Bartender screens in under 5 milliseconds.
- **Direct Peripheral Control:** POS registers communicate directly with thermal receipt printers using raw ESC/POS byte streams over TCP (port 9100), USB bulk endpoints, or Bluetooth SPP/GATT profiles. The cash drawer kick solenoid is fired via ESC/POS `27, 112, 0, 25, 250` pulse sequences without server mediation.
- **Resilient Partition Recovery:** Periodic keep-alive heartbeats detect if a satellite tablet has dropped off local Wi-Fi. Satellite orders queue locally and auto-flush to the Master POS once the local socket reconnects.

1.4 Cloud Synchronization Engine (Outbox Queue & Conflict Resolution)

Cloud replication is handled by the `SyncService` engine connecting to Supabase:

- **Transactional Outbox Queue:** All local database changes generate an entry in a local `sync_queue` table recording the table name, record ID, JSON mutation payload, and timestamp.
- **Asynchronous Synchronization Worker:** A persistent background timer (5-second cadence) polls the outbox queue. If the internet is reachable (verified via lightweight HTTP health probes), mutations are transmitted in batches to Supabase PostgREST endpoints.
- **Conflict Resolution Strategy:** FlexiTap utilizes a **Deterministic Monotonic Timestamp with Last-Write-Wins (LWW)** conflict algorithm combined with strict tenant ownership validation. If a record was modified concurrently on two devices, the write with the higher timestamp is applied, and conflicting stock deductions reconcile via additive delta logs.

1.5 Cloud Storage & Automated Disaster Recovery Pipeline

To safeguard business continuity against device theft, fire, or catastrophic hardware failure:

- **Automated Morning Snapshot:** During the first morning register boot (`performMorningBackupCheck`), the system verifies whether a cloud backup exists for the current calendar date.
- **In-Memory Gzip Compression:** The live SQLite database (`flexitap.db`) is read as raw binary, compressed via `GZipCodec` in memory, and formatted as `<storeId>/<storeId>_<YYYY-MM-DD>.bak`.
- **Scoped Upload:** The binary payload is transmitted to the private Supabase `backups` storage bucket via authenticated REST upload.
- **Client-Side 7-Day Pruning:** To conserve merchant cloud storage and enforce data minimization, the client queries its folder contents and deletes backups older than 7 days, maintaining a rolling 7-day snapshot buffer.
- **One-Click Safe Boot Restoration:** Onboarding new or replacement hardware allows the merchant to authenticate and view all available cloud snapshots in `CloudBackupSelectionScreen`. The selected `.bak` is downloaded, decompressed, verified for SQLite schema integrity, and restored seamlessly.

1.6 Web Back Office Management Portal Architecture

The FlexiTap Back Office Web Portal (`portal.html`) and Operations Portal (`dev-portal.html`) deliver desktop browser administration:

- **Pure Vanilla Architecture:** Built using clean, modern Vanilla ES6+ JavaScript, CSS3 Grid/Flexbox, and the official `@supabase/supabase-js` SDK. Eliminates heavy frontend framework dependencies, runtime bloat, and supply-chain vulnerabilities.
- **Direct PostgREST Integration:** The portal interacts directly with Supabase PostgreSQL over TLS 1.3, protected by Row-Level Security policies.
- **Tenant-Isolated Realtime Broadcasts:** Real-time sales and inventory telemetry stream over Supabase Realtime WebSocket broadcast channels strictly segregated by store identifier (`store_reports_relay_<storeId>`).

1.7 Diagnostic Support Tunnel (RustDesk Bridge)

For enterprise and Founders Pro tier troubleshooting, FlexiTap integrates an on-demand **RustDesk** remote assistance architecture:

- **Merchant-Initiated Supervised Access:** Remote support is completely inert by default. It can only be activated by the merchant explicitly navigating to the Support screen and generating a randomized 6-digit session passkey.
- **Zero Background Daemons:** No unattended background service, persistent daemon, or hidden listening ports exist on the merchant device. The session terminates immediately when the merchant taps "Disconnect" or closes the support window.

2. End-to-End Security Architecture & Controls

2.1 Multi-Tier Defense Matrix & Hardening Verification

FlexiTap adheres to a defense-in-depth posture spanning the application binary, local storage, network transport, database engine, and administrative portals:

SECURITY LAYER	IMPLEMENTED SECURITY CONTROLS	TARGET VULNERABILITY MITIGATED	VERIFICATION
Edge POS Client	OS application sandbox; memory-safe Dart runtime; Manager PIN step-up verification for Voids, Refunds, and Re-openings.	Local privilege escalation; unauthorized staff refunds; inventory shrinkage.	HARDENED
Local Storage	SQLite WAL mode; isolated filesystem paths; sanitized parameterized queries preventing SQL injection.	Data corruption on power loss; local SQL injection; cross-app data leaks.	VERIFIED
Network Transport	Enforced TLS 1.3 encryption; Cloudflare DDoS & SSL edge proxy; LAN socket isolation on port 45455.	Man-in-the-Middle (MitM) eavesdropping; session hijacking; packet inspection.	ENFORCED
Database Engine	PostgreSQL Row-Level Security (RLS) on 100% of tables; complete revocation of `anon` public permissions.	Cross-tenant data exposure; horizontal authorization bypass; unauthorized public scraping.	ZERO ALERTS
Cloud Storage	Private bucket (`public=false`); PL/pgSQL security definer RLS functions enforcing folder=store_id ownership.	Unauthorized backup downloads; data exfiltration of database snapshots.	SECURED
Web Back Office	DOM text-node rendering; sanitization of dynamic attributes; store-isolated broadcast channels; blocked client role escalation.	Stored XSS; DOM injection; unauthorized developer mode bypass; role tampering.	HARDENED

2.2 Identity, Session Tokens & Staff PIN Authentication (RBAC)

FlexiTap separates merchant account administration from daily cashier checkout operations:

- **Merchant Account Authentication:** Handled via Supabase Auth utilizing JSON Web Tokens (JWT) signed with asymmetric RS256 algorithms. Tokens carry an expiration lifespan of 1 hour, renewed automatically via cryptographically random refresh tokens stored in secure browser storage.
- **Staff PIN Access Control:** On the POS terminal, employees authenticate using numeric PIN codes. PINs are verified against local SQLite records via cryptographic hash checks.
- **Granular Role Hierarchy:**
  1. `Cashier` : Can punch orders, apply standard line-item modifiers, tender payments, print receipts, and recall their own shift tickets.
  2. `Waiter` : Can open table tickets, add kitchen items, and print bill previews. Cannot finalize payments or access cash drawers.

3. `Kitchen Staff`: Read-only access to Kitchen Display System (KDS) stations; can bump tickets to "Preparing" or "Ready".
4. `Manager`: Can authorize item voids, customer refunds, ticket re-openings, view store-wide sales reports, and perform cash drawer audits.
5. `Admin / Owner`: Full permissions including catalog pricing, tax definitions, staff management, payroll reports, and account settings.

2.3 High-Privilege Operational Safeguards (Void / Refund / Reopen)

In retail and food service environments, insider theft and shrinkage frequently occur via fraudulent ticket cancellations or phantom refunds. FlexiTap enforces an ironclad step-up security gate:

- **Cashier Personal Portal Isolation:** In `My Personal Portal` (`employee_portal_screen.dart`), cashiers can review their own shift sales, closed tickets, and reprint receipts without managerial interference.
- **Manager PIN Challenge Gate:** If a cashier initiates a **Void**, **Refund**, or **Re-open Ticket** action, the system executes `_promptForManagerPin()`:

  > **Code Enforcement in recall_ticket_dialog.dart**
  >
  > The modal blocks UI execution and queries `DatabaseService.instance.authenticatePin(pin)`. The operation proceeds **only** if the authenticating user possesses the `UserRole.manager` or `UserRole.admin` permission bit.

- **Full Ledger Reversal:** When a refund or reopen is authorized, the system atomically updates the original invoice status, reverses inventory deduction quantities, updates the cashier's active shift cash drawer balance, and restores the items back into the active cart provider.

2.4 Multi-Tenant Row-Level Security (RLS) & Public API Lockdown

Multi-tenancy in FlexiTap is enforced directly in the database kernel using PostgreSQL Row-Level Security:

- **Universal RLS Activation:** Every table in the public schema has RLS enabled via `ALTER TABLE public.<table_name> ENABLE ROW LEVEL SECURITY;`.
- **Tenant Scoping Condition:** Policies enforce that incoming queries evaluate against the authenticated identity: `USING (owner_id::text = auth.uid()::text OR user_id::text = auth.uid()::text OR store_id IN (SELECT id FROM public.stores WHERE owner_id::text = auth.uid()::text))`.
- **Revocation of Public `anon` Privileges:** Executed across all 10 legacy tables via `supabase_phase3_advisor_remediation.sql`:
  `REVOKE ALL ON TABLE public.users, public.invoices, public.invoice_items, public.items, public.categories, public.taxes, public.prep_stations, public.pos_devices, public.departments, public.item_prep_stations FROM anon;`
  This guarantees that unauthenticated requests received by the PostgREST API encounter zero readable or writable tables.

2.5 Cloud Storage Hardening & Backup Object Isolation

The Supabase Storage infrastructure is secured via `supabase_storage_hardening.sql`:

- **Private Bucket Flag:** The `backups` bucket has `public = false`, disabling all unauthenticated public URL downloads.
- **Security Definer Storage Gate:** Access to `storage.objects` evaluates the PL/pgSQL function `public.can_access_backup_object(object_name)`:

1. Rejects unauthenticated sessions (`auth.uid() IS NULL`).
2. Extracts the root folder from the object path (`(storage.foldername(name))[1]`).
3. Validates that the folder matches either the authenticated user ID, the `store_id` in the user's profile, or a store where the user is recorded as owner.

2.6 Web Portal Hardening (XSS, Escalation & Sanitization)

The web portals (`portal.html` and `dev-portal.html`) have undergone comprehensive Phase 2 hardening:

- **DOM XSS Elimination:** Replaced all dynamic `innerHTML` assignments with safe `document.createTextNode()` and DOM construction methods. Dynamic merchant inputs (such as business names, menu items, and feedback messages) cannot execute malicious scripts.
- **Attribute Sanitization:** Leads tables and administrative action buttons use rigorous attribute escaping, preventing quote-breaking injection vectors.
- **Role Escalation Prevention:** The client-side signup flow strictly prevents writing `user_metadata.role: 'admin'`. User roles are governed strictly by database-level security policies and backend claims.
- **Inspection Parameter Suppression:** The `?dev_inspect=true` bypass flag has been removed, ensuring developer tooling cannot be triggered by unauthenticated third parties.

2.7 Cryptography, Data in Transit & Data at Rest

- **Transport Layer Security:** All external communication utilizes TLS 1.3 with cipher suites enforcing forward secrecy (ECDHE-ECDSA-AES128-GCM-SHA256, ECDHE-RSA-AES256-GCM-SHA384).
- **Database at Rest:** Cloud databases run on AWS managed RDS instances equipped with AES-256 transparent data encryption (FIPS 140-2 validated hardware).
- **Device Hardware Encryption:** Local edge databases inherit the physical device's native hardware-backed encryption (Android FBE using ARM TrustZone / Knox; Apple iOS/macOS Secure Enclave; Windows BitLocker).

3. Payment Architecture & PCI DSS Boundary Analysis

3.1 Merchant of Record (Paddle) Architecture & PCI DSS Level 1 Scope

FlexiTap employs an architectural decoupling strategy for software subscription payments and licensing by partnering with **Paddle (Paddle.com Market Ltd)** as its authorized **Merchant of Record (MoR)**.

- **PCI DSS Level 1 Compliance Inheritance:** Paddle is a certified PCI DSS Level 1 Service Provider. All credit and debit card intake for FlexiTap SaaS subscriptions occurs exclusively within Paddle-hosted, PCI-compliant iframes (`Paddle.js v2`).
- **Zero Cardholder Data Exposure:** Card Primary Account Numbers (PANs), expiration dates, CVVs, and cardholder billing addresses are transmitted directly from the subscriber's browser to Paddle's vault. No cardholder data ever enters, traverses, or touches FlexiTap web servers, cloud functions, or databases.
- **Global Sales Tax & Invoicing Remittance:** As Merchant of Record, Paddle legally assumes responsibility for calculating, invoicing, collecting, and remitting sales taxes, VAT, and GST across more than 200 sovereign jurisdictions worldwide.
- **Cryptographic Webhook Ingestion:** When subscription events occur (activations, renewals, upgrades, cancellations), Paddle transmits asynchronous webhooks to FlexiTap. Every webhook is cryptographically validated using HMAC-SHA256 signatures before subscription entitlements are applied.

3.2 In-Store Retail & Restaurant Card Payment Flow

For in-store physical transactions conducted at merchant checkout lanes, FlexiTap maintains strict **Physical and Logical Separation** from credit and debit card processing:

TRANSACTION COMPONENT	OPERATING ARCHITECTURE	PCI DSS SCOPE IMPACT
Payment Terminal Hardware	Stand-alone, bank-provided EMV chip / contactless NFC payment terminal (Verifone, Ingenico, Pax, Sunmi) supplied directly by merchant's acquiring bank.	**100% Out of Scope** for FlexiTap. Managed under acquiring bank's PCI-PTS certification.
Card Reading & PIN Entry	Card is tapped, dipped, or swiped exclusively on the external terminal. Terminal communicates directly with payment processor via cellular or merchant banking network.	**Zero Transmission** across FlexiTap hardware, POS memory, or local databases.
POS Transaction Completion	Cashier selects "Credit/Debit Card" in FlexiTap tender modal and inputs the terminal's printed approval code and transaction amount.	Only non-sensitive operational metadata is stored: Payment method, amount, reference code, timestamp.

3.3 Alternative Tender Types: Cash, E-Wallets, QR Ph & Store Credit

FlexiTap provides rich support for diverse retail tender types without touching regulated financial networks:

- **Cash Management:** Exact calculations for gross amount, tendered cash, and change due. Cash drawer kick pulse triggered via printer hardware. Mid-day cash drops, petty cash payouts, and blind end-of-shift drawer reconciliations are logged with manager audit trails.

- **E-Wallets & QR Ph (GCash, Maya, PromptPay, PIX):** Terminal displays dynamic or static QR payment codes. The customer scans with their banking app; cashier verifies transfer on merchant's payment terminal and records the wallet reference number.
- **Accounts Receivable (Customer Store Accounts / Credit Ledger):** Allows trusted commercial customers to charge orders to their account. Tracks credit limits, ledger history, payment collections, and outstanding aging balances locally.

3.4 Strict Technical & Contractual Cardholder Data Exclusion

> **PCI DSS Scope Exclusion Affirmation**
>
> FlexiTap does NOT capture, transmit, store, or process payment card Primary Account Numbers (PANs), Card Verification Values (CVV / CVC / CID), PINs, PIN blocks, or full magnetic stripe / EMV chip track data.

This exclusion is contractually enforced in **Section 3 of the FlexiTap Terms of Service**:

> *"You agree not to... enter, transcribe, or store payment card Primary Account Numbers (PANs), Card Verification Values (CVV / CVC), PINs, or magnetic stripe / EMV chip data in any free-text, note, remark, or custom field within the Service. Card payments processed at your checkout must be transacted directly via external PCI-compliant payment terminals or accredited gateway hardware; FlexiTap does not store or process raw cardholder data."*

Consequently, under the **Payment Card Industry Data Security Standard (PCI DSS v4.0)**, FlexiTap software, servers, and cloud databases are **ENTIRELY EXCLUDED** from the merchant's Cardholder Data Environment (CDE). Merchants utilizing FlexiTap alongside stand-alone external terminals qualify for the simplest self-assessment validation standard (typically PCI DSS SAQ-A or SAQ B-VT).

4. Terms of Service, Privacy Policy & Regulatory Framework

4.1 Legal Role Demarcation: Data Controller (PIC) vs. Processor (PIP)

In compliance with international data privacy legislation (GDPR Art. 4, CCPA/CPRA, and Philippine Data Privacy Act RA 10173), FlexiTap contractually establishes clear institutional role boundaries:

- **FlexiTap as Data Controller (Personal Information Controller / PIC):** FlexiTap acts as Data Controller *solely* for information collected directly from the merchant account holder to establish the commercial relationship: business owner email, store name, physical address, locale, subscription tier, and Paddle customer identifier.
- **FlexiTap as Data Processor (Personal Information Processor / PIP):** For all data entered into the POS by the merchant—including consumer names, phone numbers, delivery addresses, customer debt ledgers, employee timecards, and itemized transaction receipts—**the merchant acts as the sole Data Controller (PIC)**. FlexiTap operates strictly as a **Data Processor (PIP)**, storing and synchronizing such data solely on the documented instructions of the merchant to provide the Service.

4.2 Detailed Analysis of the Four Protective Statutory Disclaimers

The FlexiTap legal architecture embeds four robust protective clauses across `terms.html` and `privacy.html` to shield the organization and provide transparent operational clarity to merchants:

PROTECTIVE CLAUSE	CONTRACTUAL PROVISION SUMMARY	STATUTORY RISK SHIELDED
1. PCI DSS Exclusion Clause `terms.html` Sec 3 `privacy.html` Sec 2	Explicit prohibition against entering 16-digit card PANs, CVVs, or track data into note or customer fields; clarifies that card payments are transacted off-system on bank terminals.	Shields FlexiTap from PCI DSS CDE scope, audit costs, and breach liability for cardholder data compromises.
2. HIPAA & PHI Exclusion Clause `terms.html` Sec 7 `privacy.html` Sec 2	Express disclaimer stating FlexiTap is NOT a Business Associate or Covered Entity under HIPAA; strictly forbids storing patient medical records or Protected Health Information (PHI).	Eliminates applicability of US HIPAA/HITECH security rules, audits, and statutory healthcare penalties.
3. Philippine BIR Non-OR Notice `terms.html` Sec 8 Schedule Receipt Slip Footers	Clear notice under RA 8424 and BIR Revenue Regulations (RR 11-2004, RR 10-2012) stating the POS prints internal order slips, NOT statutory Official Receipts (OR) or Sales Invoices (SI).	Protects against merchant claims regarding BIR fiscal accreditation, tax deficiencies, and administrative store closures (Oplan Kandado).
4. Wage, Hour & Overtime Disclaimer `terms.html` Sec 8 Schedule	Affirms that employee timeclock tracking and break logs are operational tracking tools; merchant holds exclusive duty for statutory wage, overtime, and labor law compliance.	Shields from statutory labor disputes, employee wage-and-hour lawsuits, and FLSA / DOLE statutory penalties.

4.3 Global Privacy Law Compliance Mapping

FlexiTap aligns with major privacy jurisdictions worldwide:

- **GDPR / UK GDPR (European Union & United Kingdom):**
  - *Lawful Basis (Art. 6):* Processing is grounded in performance of contract with the merchant and legitimate operational interests.

- *Data Minimization (Art. 5):* Only operational data necessary for point-of-sale execution is collected. Crash diagnostics exclude business transaction payloads.
- *Security of Processing (Art. 32):* Technical measures include TLS 1.3 encryption, database RLS, and encrypted cloud storage.
- *Data Subject Rights:* Support for right of access, rectification, and erasure.

- **CCPA / CPRA (California, United States):**
  - *Service Provider Status:* FlexiTap qualifies as a "Service Provider" processing personal information on behalf of businesses.
  - *Zero Sale or Sharing of Data:* FlexiTap warrants that it does NOT sell, rent, or share personal information for cross-context behavioral advertising. The software is 100% ad-free across all tiers.
- **Philippine Data Privacy Act of 2012 (Republic Act No. 10173):**
  - Adheres to statutory principles of Transparency, Legitimate Purpose, and Proportionality (Sec. 11).
  - Full support for Section 16 Data Subject Rights: Right to be informed, access, object, erasure or blocking, rectification, and right to lodge a formal complaint with the **National Privacy Commission (NPC)** (`privacy.gov.ph`).

4.4 Data Lifecycle, Retention Periods & Self-Service Deletion

- **Active Subscription Retention:** Operational transaction data is retained during the active lifecycle of the merchant account.
- **Rolling Cloud Backup Retention:** Automated database snapshots in Supabase Storage operate on a strict 7-day client rotation cycle. Backups older than 7 days are automatically pruned.
- **Automated Self-Service Account Erasure:** Merchants possess the absolute right to terminate their account at any time via `https://flexitapapp.com/account/delete`. Execution triggers cascading deletions that permanently remove the merchant profile, store records, devices, and cloud backup archives within 30 days.

4.5 Subscription Terms, Cancellation & 14-Day Refund Guarantee

- **Tier Transparency:** FlexiTap offers a permanently Free tier (single-device, 100% ad-free, local storage) and paid tiers (Founders Pro / Enterprise) with multi-device sync and cloud backup features.
- **14-Day Statutory Refund Policy:** First-time paid subscribers can request a full, no-questions-asked refund within 14 calendar days of initial billing by contacting `support@flexitapapp.com`.
- **Hassle-Free Cancellation:** Subscriptions can be canceled at any time directly through the merchant web portal or Paddle customer billing dashboard. Canceled subscriptions remain active until the end of the prepaid billing cycle with no cancellation fees or penalties.

5. Platform Evaluation, Threat Modeling & Independent Audit Matrix

5.1 STRIDE Threat Modeling Evaluation

An engineering evaluation of the FlexiTap platform under Microsoft's STRIDE threat model:

THREAT CATEGORY	POTENTIAL ATTACK VECTOR	ENGINEERED COUNTERMEASURE	RISK LEVEL
Spoofing	Attacker impersonates a merchant register or forges sync requests.	Supabase JWT token validation; device ID matching; TLS client verification.	LOW
Tampering	Interception and modification of sync payloads in transit.	Mandatory TLS 1.3 across all network interfaces; deterministic schema validation.	LOW
Repudiation	Cashier denies performing a void, refund, or shift cash drawer alteration.	Manager PIN step-up audit logs; cashier ID stamped on every invoice mutation.	LOW
Information Disclosure	Unauthorized actor scrapes multi-tenant database or accesses backup files.	PostgreSQL RLS on 100% of tables; public=false on storage; revoked anon permissions.	LOW
Denial of Service	Cloud outage or network flood halts store checkout operations.	Offline-first local SQLite engine; 100% autonomous edge operation without internet.	LOW
Elevation of Privilege	Attacker modifies client payload to claim 'admin' role in user metadata.	Removal of client-writable user_metadata.role; database RLS verifies store ownership.	LOW

5.2 Regulatory Standards Compliance Mapping Table

STANDARD	REGULATORY SCOPE STATUS	TECHNICAL & LEGAL VERIFICATION EVIDENCE	AUDIT POSTURE
PCI DSS v4.0	**Excluded from Scope**. Zero cardholder data stored or transmitted; SaaS billing via Paddle; in-store via bank terminals.	`terms.html` Sec 3; `privacy.html` Sec 2; absence of PAN fields in SQLite schema.	EXCLUSION VALIDATED
GDPR / UK GDPR	**Compliant Data Processor**. DPA terms active; technical security implemented; self-service erasure endpoint operational.	`privacy.html` Sec 1 & 9; automated deletion route at `/account/delete`; RLS isolation.	VERIFIED
CCPA / CPRA	**Compliant Service Provider**. Zero data sale or sharing; supports consumer access and deletion requests.	`privacy.html` Sec 9 California Schedule; ad-free architecture.	VERIFIED
PH DPA (RA 10173)	**Compliant PIP**. Adheres to Section 16 rights, NPC reporting framework, technical encryption, and security disclaimers.	`privacy.html` Sec 9 Philippine Schedule; encryption at rest; security measures documentation.	VERIFIED
HIPAA / HITECH	**Excluded from Scope**. Software expressly disclaims suitability for patient Protected Health Information (PHI).	`terms.html` Sec 7 HIPAA Exclusion Clause; `privacy.html` Sec 2.	EXCLUSION VALIDATED
Philippine BIR PTU	**Operational Control Tool**. Clarified as non-fiscal internal order printer; merchants must issue manual registered BIR receipts.	`terms.html` Sec 8 BIR Schedule; non-OR footer on customer slips.	NOTICE ENFORCED
US FLSA & Labor Laws	**Operational Time Tracker**. Timecards are uncertified raw logs; merchant holds sole duty for wage/overtime calculations.	`terms.html` Sec 8 Labor Schedule.	DISCLAIMER ENFORCED

5.3 Technical Verification & Control Evidence Repository

Independent auditors can verify all assertions in this dossier against the following repository artifacts:

- **POS High-Privilege Guard:** `lib/core/navigation/recall_ticket_dialog.dart` (Lines 270-340: `_promptForManagerPin()` enforcing `UserRole.manager` / `UserRole.admin` before Void/Refund/Re-open).
- **Cashier Portal Scoping:** `lib/core/navigation/employee_portal_screen.dart` (Quick Actions & Closed Tickets browser scoped to active shift cashier).
- **Database RLS Remediation:** `supabase_phase3_advisor_remediation.sql` (RLS activation on 10 legacy tables, revocation of `anon`).
- **Storage Lockdown Migration:** `supabase_storage_hardening.sql` (Sets `public = false` on `backups` bucket; installs `can_access_backup_object` RLS function).

- **Web Portal Defenses:** `portal.html` and `dev-portal.html` (DOM text-node rendering, removal of `?dev_inspect=true`, blocking client role escalation).
- **Legal Disclaimers:** `terms.html` (Sections 3, 6, 7, 8) and `privacy.html` (Sections 1, 2, 4, 8, 9).

5.4 Independent Reviewer Attestation & Sign-Off Protocol

> **Conclusion & Auditor Attestation**
>
> The architectural, security, payment, and legal measures implemented across the FlexiTap POS platform represent an enterprise-grade, privacy-first posture suitable for retail, restaurant, and enterprise merchant deployments globally.

INDEPENDENT AUDITOR ATTESTATION & REVIEW SIGN-OFF

By signing below, the independent reviewer confirms that they have examined the technical architecture, security configurations, database RLS policies, payment boundary definitions, and legal disclaimers of the FlexiTap POS platform as described herein.

Auditor Name: _____

Signature: _____

Review Firm / Organization: _____

Date of Evaluation: _____

Professional Title: _____

Audit Determination: [ ] SATISFACTORY [ ] EXCEPTIONS NOTED